

安全加固报告 FIX-06：文件上传、WebShell与木马文件识别

修复漏洞类型：文件上传、WebShell与木马文件识别

修复小组：天亮了么

修复时间：2026-08-25

对应漏洞报告：VULN-06-文件上传、WebShell与木马文件识别

修复负责人：蒲云楷

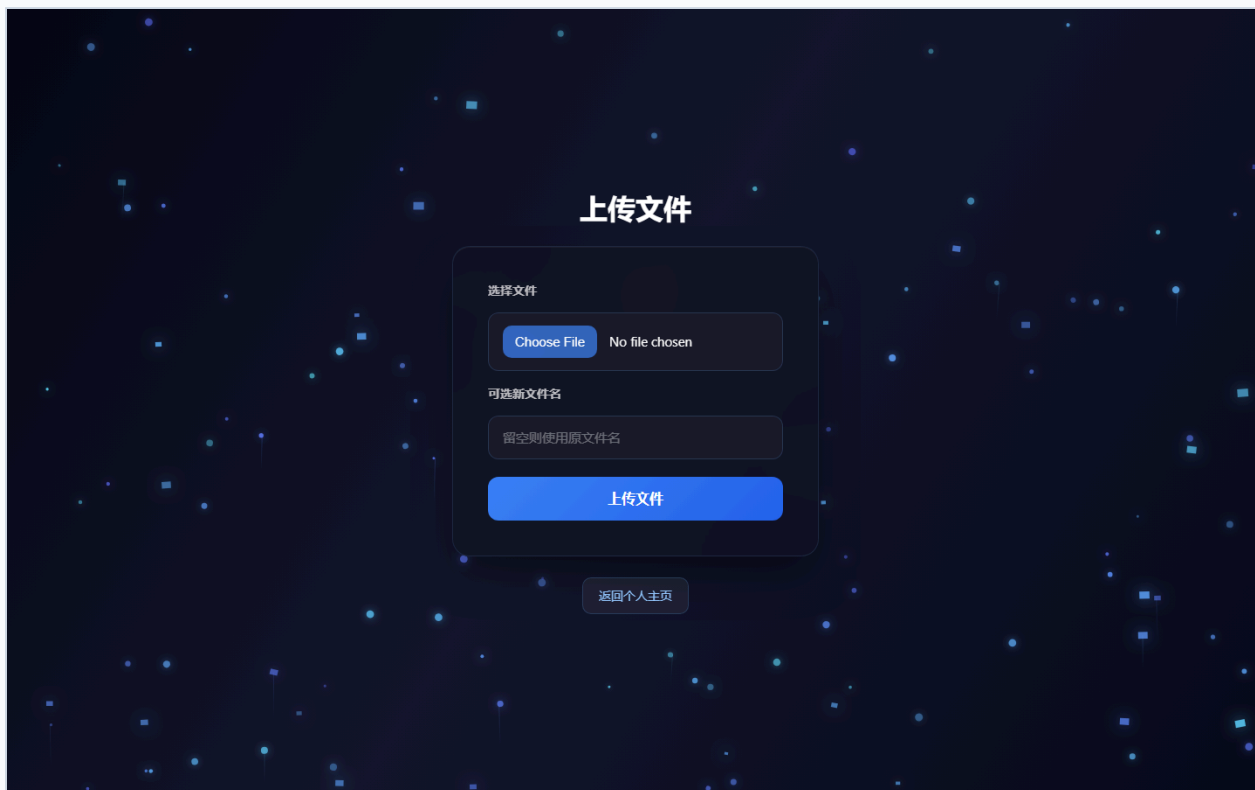
1. 基本信息

本报告按附录A记录阶段二任务6的修复和验证。

2. 漏洞复现情况

是否能按攻击方步骤复现：修复前基线已记录；修复后原始参数应被拦截或不产生越权效果。

复现环境：本机 127.0.0.1:5001。



Pretty-print ☐

```
[{"error": "\u4e0d\u652f\u6301\u7684\u6587\u4ef6\u7c7b\u578b"}]
```

Pretty-print ☐

```
[{"error": "\u6587\u4ef6\u5185\u5bb9\u4e0e\u6269\u5c55\u540d\u4e0d\u5339\u914d"}]
```

pyknb 的文件

上传新文件

返回个人主页

退出登录

文件名	操作
44286_2023_2_Fig5_HTML.webp	下载 删除
fake.png	下载 删除
scriptalert1_script.png	下载 删除

任务 06 修复代码证据

gets.py:20-42

```

20
21 app = Flask(__name__)
22 app.secret_key = os.environ.get("FLASK_SECRET_KEY") or secrets.token_hex(32)
23 app.config.update(
24     SESSION_COOKIE_HTTPONLY=True,
25     SESSION_COOKIE_SAMESITE="Lax",
26     SESSION_COOKIE_SECURE=os.environ.get("FLASK_COOKIE_SECURE", "0") == "1",
27     MAX_CONTENT_LENGTH=16 * 1024 * 1024,
28 )
29 logging.basicConfig(level=logging.INFO, format="%(asctime)s %(levelname)s %(message)s")
30 security_logger = logging.getLogger("webdrive.security")
31
32 db_config = {
33     "host": os.environ.get("DB_HOST", "localhost"),
34     "user": os.environ.get("DB_USER", "root"),
35     "password": os.environ.get("DB_PASSWORD", "pyk114514"),
36     "database": os.environ.get("DB_NAME", "account_id"),
37     "charset": "utf8mb4",
38 }
39 UPLOAD_FOLDER = os.path.join(os.path.dirname(os.path.abspath(__file__)), "uploads")
40 app.config["UPLOAD_FOLDER"] = UPLOAD_FOLDER
41
42 LOGIN_MAX_FAILURES = 5

```

gets.py:309-349

```

309 def upload_file():
310     if "username" not in session:
311         return redirect("/login")
312     if request.method == "GET":
313         return render_template("upload.html")
314     supplied = request.form.get("csrf_token")
315     if not supplied or not secrets.compare_digest(supplied, session.get("csrf_token", "")):
316         return jsonify({"error": "请求验证失败，请刷新页面后重试"}), 403
317     result = _save_upload(request.files.get("file"), request.form.get("customName", ""))
318     return redirect("/listfiles") if result[1] == 200 else result
319
320
321 def _save_upload(file, custom_name=""):
322     if not file or not file.filename:
323         return jsonify({"error": "请选择文件"}), 400
324     filename = secure_filename(custom_name.strip() or file.filename)
325     if not filename:
326         return jsonify({"error": "文件名无效"}), 400
327     extension = filename.rsplit(".", 1)[-1].casefold() if "." in filename else ""
328     if extension not in ALLOWED_EXTENSIONS:
329         security_logger.warning("upload_rejected username=%s ip=%s filename=%s reason=extension", session.get("username"), client_ip(),
filename)
330         return jsonify({"error": "不支持的文件类型"}), 400
331     if file.content_length and file.content_length > app.config["MAX_CONTENT_LENGTH"]:
332         return jsonify({"error": "文件大小超过限制"}), 413
333     signatures = FILE_SIGNATURES.get(extension)
334     if signatures:
335         header = file.stream.read(16)
336         file.stream.seek(0)
337         if not any(header.startswith(signature) for signature in signatures):
338             security_logger.warning("upload_rejected username=%s ip=%s filename=%s reason=file_signature", session.get("username"),
client_ip(), filename)
339             return jsonify({"error": "文件内容与扩展名不匹配"}), 400
340     user_dir = os.path.join(app.config["UPLOAD_FOLDER"], session["username"])
341     os.makedirs(user_dir, exist_ok=True)
342     file.save(os.path.join(user_dir, filename))
343     security_logger.info("upload_success username=%s ip=%s filename=%s", session.get("username"), client_ip(), filename)
344     return jsonify({"success": True, "file": filename}), 200
345
346
347 @app.post("/api/files")
348 @api_login_required
349 @csrf_protected

```

3. 根因定位

相关文件：gets.py、相关模板和前端 API 客户端。

相关函数或接口：/upload、/api/files；字段 file、customName。

问题代码/根因：原先主要依赖文件名安全化，缺少扩展名、大小和真实文件类型校验。

4. 修复措施

修改点1

修改文件：gets.py。

修改前逻辑：缺少统一安全边界或校验。

修改后逻辑：增加16MB请求限制、扩展名白名单、PDF/PNG/JPEG/GIF/WEBP/ZIP文件头校验、secure_filename、拒绝日志；上传目录部署为非执行目录。

修改点2

修改文件：相关 HTML/CSS/前端 API（按任务适用）。

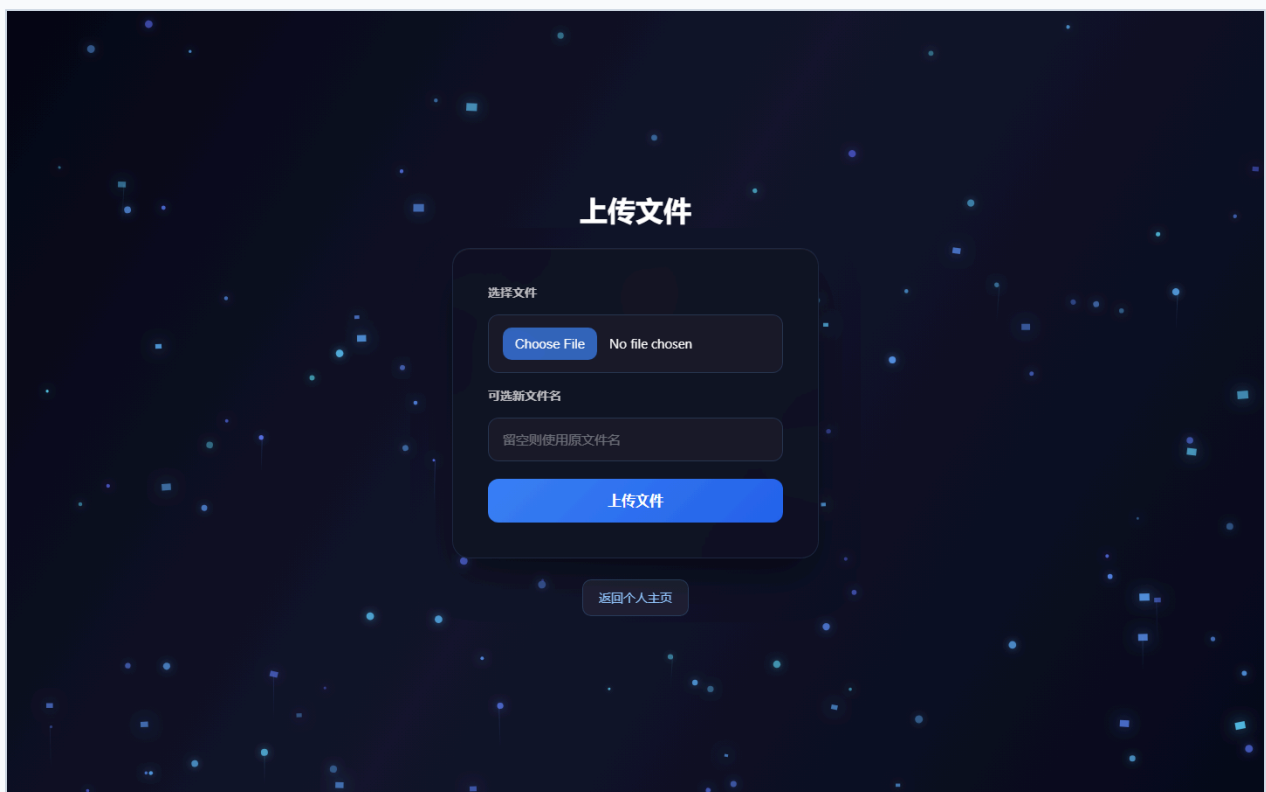
修改后逻辑：页面和客户端与服务端安全校验保持一致，不能替代服务端校验。

5. 修复后验证

使用攻击方原始步骤重新测试：

1. 发送原始无害测试参数。
2. 观察状态码、页面、数据、文件和日志。
3. 确认原攻击失效并保存截图。

验证结果：payload.exe 被扩展名白名单拒绝；文本内容伪装为 fake.png 时被文件头校验拒绝。
原攻击是否失效：是（本机回归测试）



Pretty-print ☐

```
[{"error": "\u4e0d\u652f\u6301\u7684\u6587\u4ef6\u7c7b\u578b"}]
```

Pretty-print ☐

```
[{"error": "\u6587\u4ef6\u5185\u5bb9\u4e0e\u6269\u5c55\u540d\u4e0d\u5339\u914d"}]
```

pyknb 的文件

上传新文件

返回个人主页

退出登录

文件名	操作
44286_2023_2_Fig5_HTML.webp	下载 删除
fake.png	下载 删除
scriptalert1_script.png	下载 删除

任务 06 修复代码证据

gets.py:20-42

```

20
21 app = Flask(__name__)
22 app.secret_key = os.environ.get("FLASK_SECRET_KEY") or secrets.token_hex(32)
23 app.config.update(
24     SESSION_COOKIE_HTTPONLY=True,
25     SESSION_COOKIE_SAMESITE="Lax",
26     SESSION_COOKIE_SECURE=os.environ.get("FLASK_COOKIE_SECURE", "0") == "1",
27     MAX_CONTENT_LENGTH=16 * 1024 * 1024,
28 )
29 logging.basicConfig(level=logging.INFO, format="%(asctime)s %(levelname)s %(message)s")
30 security_logger = logging.getLogger("webdrive.security")
31
32 db_config = {
33     "host": os.environ.get("DB_HOST", "localhost"),
34     "user": os.environ.get("DB_USER", "root"),
35     "password": os.environ.get("DB_PASSWORD", "pyk114514"),
36     "database": os.environ.get("DB_NAME", "account_id"),
37     "charset": "utf8mb4",
38 }
39 UPLOAD_FOLDER = os.path.join(os.path.dirname(os.path.abspath(__file__)), "uploads")
40 app.config["UPLOAD_FOLDER"] = UPLOAD_FOLDER
41
42 LOGIN_MAX_FAILURES = 5

```

gets.py:309-349

```

309 def upload_file():
310     if "username" not in session:
311         return redirect("/login")
312     if request.method == "GET":
313         return render_template("upload.html")
314     supplied = request.form.get("csrf_token")
315     if not supplied or not secrets.compare_digest(supplied, session.get("csrf_token", "")):
316         return jsonify({"error": "请求验证失败，请刷新页面后重试"}), 403
317     result = _save_upload(request.files.get("file"), request.form.get("customName", ""))
318     return redirect("/listfiles") if result[1] == 200 else result
319
320
321 def _save_upload(file, custom_name=""):
322     if not file or not file.filename:
323         return jsonify({"error": "请选择文件"}), 400
324     filename = secure_filename(custom_name.strip() or file.filename)
325     if not filename:
326         return jsonify({"error": "文件名无效"}), 400
327     extension = filename.rsplit(".", 1)[-1].casefold() if "." in filename else ""
328     if extension not in ALLOWED_EXTENSIONS:
329         security_logger.warning("upload_rejected username=%s ip=%s filename=%s reason=extension", session.get("username"), client_ip(),
filename)
330         return jsonify({"error": "不支持的文件类型"}), 400
331     if file.content_length and file.content_length > app.config["MAX_CONTENT_LENGTH"]:
332         return jsonify({"error": "文件大小超过限制"}), 413
333     signatures = FILE_SIGNATURES.get(extension)
334     if signatures:
335         header = file.stream.read(16)
336         file.stream.seek(0)
337         if not any(header.startswith(signature) for signature in signatures):
338             security_logger.warning("upload_rejected username=%s ip=%s filename=%s reason=file_signature", session.get("username"),
client_ip(), filename)
339             return jsonify({"error": "文件内容与扩展名不匹配"}), 400
340     user_dir = os.path.join(app.config["UPLOAD_FOLDER"], session["username"])
341     os.makedirs(user_dir, exist_ok=True)
342     file.save(os.path.join(user_dir, filename))
343     security_logger.info("upload_success username=%s ip=%s filename=%s", session.get("username"), client_ip(), filename)
344     return jsonify({"success": True, "file": filename}), 200
345
346
347 @app.post("/api/files")
348 @api_login_required
349 @csrf_protected

```

6. 额外加固

统一错误提示、输入长度限制、安全日志、Cookie 安全属性、调试模式关闭和生产密钥配置要求。

7. 仍需改进

课程组别、负责人、Git tag 等元数据需在提交前填写；HTTPS 部署时启用 Secure Cookie；Web 服务器需确认上传目录不可执行。